

对 DeepSeek 遭受网络攻击事件的分析

摘要

本文分析了 DeepSeek 在 2025 年 1 月遭遇的网络攻击事件。由于 DeepSeek 的 AI 模型发布后吸引了大量用户，服务器频繁出现“服务器繁忙”错误提示，调查发现，这一现象不仅源于用户爆炸增长，更与网络攻击相关。攻击主要来自 DDoS 攻击、密码爆破和应用层攻击。DDoS 攻击通过恶意流量耗尽服务器资源，密码爆破攻击通过暴力破解密码，而应用层攻击利用 SQL 注入和 XSS 攻击获取敏感信息。

为应对这些攻击，文章提出了多项防护措施，包括加强 DDoS 防护、部署 Web 应用防火墙（WAF）、使用多因素认证（MFA）和加密技术（如 AES）。这些措施旨在提高 DeepSeek 的网络安全性，保护用户数据，并恢复公众对公司信任。

背景

DeepSeek 是一家中国的人工智能初创公司。2025 年 1 月，DeepSeek 发布了 DeepSeek-R1 模型，迅速获得大量用户，甚至在苹果应用商店中超过了 ChatGPT 的下载量。这一突如其来的成功引发了全球关注^[1]，不少科技工作者，学生，甚至大众都希望能够体验“最强 AI”的魅力所在，而大部分人却时常受到“服务器繁忙，请稍后再试”的尴尬回复，那么服务器究竟为何“繁忙”？其背后的主要原因是 DeepSeek 在模型发布后遭到了大量的网络攻击^[2]

攻击历程与方法分析

2025 年 1 月 27 日，DeepSeek 的服务器遭遇了多轮大规模的 DDoS 攻击，攻击者通过多个代理服务器和控制的僵尸网络，不断发送大量恶意流量，消耗 DeepSeek 的带宽和服务器资源。攻击者还通过应用层攻击，例如 SQL 注入，尝试访问数据库中的敏感信息，进一步加剧了服务器的负担。

C&C 服务器 (16)

C&C 端口 (118)

目标端口 (2)

目标单位 (1)

目标行业 (1)

恶意家族 (2)

攻击形式 (3)

受攻击目标 (1)

目标国家 / 地区 (1)

目标 ASN (1)

导出 CSV

开始时间	C&C 服务器	C&C 端口	恶意家族	攻击形式	受攻击目标	DNS 记录	目标国家 / 地区
2025-01-30 02:11:51	35.1	5222	RapperBot	apk_7	60	/32	deepseek.com , +4 ...
2025-01-30 02:11:50	35.1	7777	RapperBot	apk_7	60	/32	r.deepseek.com , +4 ...
2025-01-30 02:11:47	85.3	5000	RapperBot	apk_7	60	/32	deepseek.com , +4 ...
2025-01-30 02:11:45	62.6	443	RapperBot	apk_7	60	/32	deepseek.com , +4 ...
2025-01-30 02:11:44	33.1	3724	RapperBot	apk_7	60	/32	deepseek.com , +4 ...
2025-01-30 02:11:44	33.1	27015	RapperBot	apk_7	60	/32	deepseek.com , +4 ...
2025-01-30 02:11:41	230.6	443	RapperBot	apk_7	60	/32	deepseek.com , +4 ...
2025-01-30 02:04:13	85.3	5000	RapperBot	apk_0	60	/32	deepseek.com , +4 ...
2025-01-30 02:04:10	35.1	7777	RapperBot	apk_0	60	/32	deepseek.com , +4 ...
2025-01-30 02:04:08	62.6	443	RapperBot	apk_0	60	/32	deepseek.com , +4 ...
2025-01-30 02:04:08	33.1	27015	RapperBot	apk_0	60	/32	deepseek.com , +4 ...
2025-01-30 02:04:07	33.1	5222	RapperBot	apk_0	60	/32	r.deepseek.com , +4 ...
2025-01-30 02:04:04	33.1	3724	RapperBot	apk_0	60	/32	deepseek.com , +4 ...
2025-01-30 02:04:02	230.6	443	RapperBot	apk_0	60	/32	deepseek.com , +4 ...
2025-01-30 02:01:58	35.1	7777	RapperBot	apk_6	60	/32	deepseek.com , +4 ...
2025-01-30 02:01:57	35.1	5222	RapperBot	apk_6	60	/32	deepseek.com , +4 ...
2025-01-30 02:01:56	62.6	443	RapperBot	apk_6	60	/32	r.deepseek.com , +4 ...
2025-01-30 02:01:54	33.1	3724	RapperBot	apk_6	60	/32	deepseek.com , +4 ...

图 1 DeepSeek 受到网络攻击记录（图源 CN-SEC 中文网）

下面对主要的三种攻击方式进行介绍与分析。包括 DDoS 攻击、密码爆破攻击与应用层攻击。

（一）DDoS 攻击

DDos (Distributed Denial of Service) 全称是“分布式拒绝服务攻击”。其通过破坏网络服务来锁定网站和服务器，试图耗尽应用程序的资源。执行这些攻击的罪犯会用错误的流量攻占网站，导致网站的功能不佳或者完全离线。

在 DDoS 攻击期间，一系列机器人或僵尸网络会用 HTTP 请求和流量攻占网站或服务。从本质上讲，在攻击期间会有多台计算机攻击一台计算机，导致将合法用户推出。因此，服务可能会延迟或中断一段时间。在攻击期间，黑客也有可能渗入数据库以访问敏感信息。DDoS 攻击可以利用安全漏洞并攻击可通过 Internet 公开访问的任何终结点。

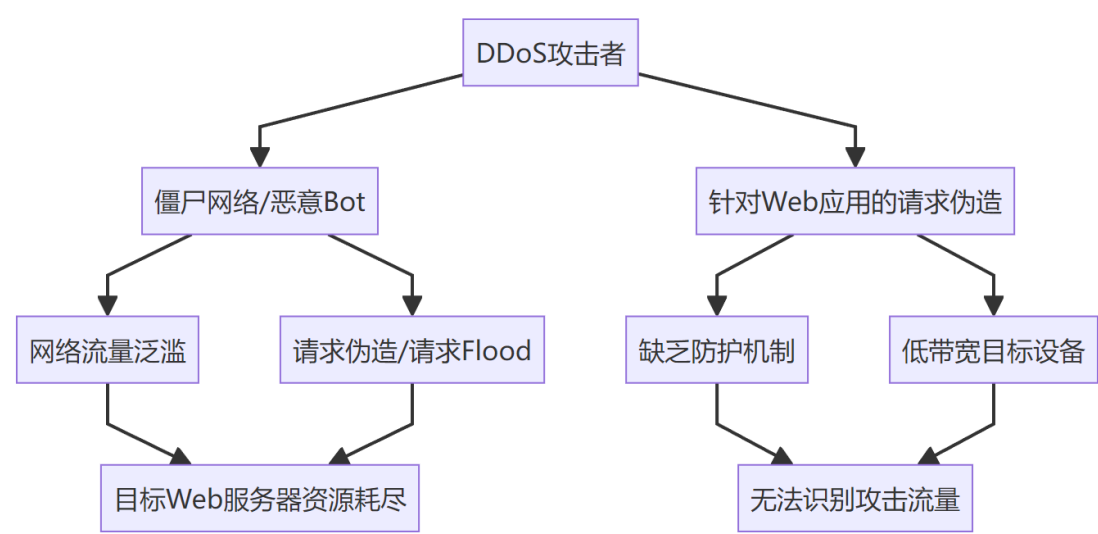


图 2 DDoS 攻击流程图

自 1 月 27 日开始，大量的 HTTP 代理攻击开始出现，以及专业的僵尸网络团伙集中火力，对 DeepSeek 的 AI 服务和数据发起了密集攻击^[3]。攻击者利用向 DeepSeek 发送大量请求的方式，使得服务器崩溃中断，而正常的用户在使用时无法正常接触到相应的服务器资源，也就是用户经常收到“服务器繁忙，请稍后再试。”的一大原因。

DDoS 攻击分为三类：容量耗尽攻击通过占用服务器带宽（如 DNS 放大攻击）使目标无法处理正常流量；协议攻击（如 SYN 洪水攻击）通过大量伪造的 SYN 请求消耗服务器资源，导致连接无法完成；资源层攻击通过发送大量虚假应用层请求（如 HTTP 请求）消耗服务器计算资源，使其无法处理合法请求。

（二）密码爆破攻击

密码爆破攻击 (Brute Force Attack) 是指攻击者通过反复尝试不同的密码组合，直到找到正确密码为止。这种攻击方式常常利用并行计算，尝试所有可能的密码组合。现代密码破解工具利用 GPU 并行计算的能力，极大地提高了破解速度。例如，使用 GPU 加速的工具可以在短短几小时内破解许多常见的密码。此外，如果系统不启用账户锁定机制（例如在多次尝试失败后锁定账户），密码爆破攻击的效率将大大提

高。

（三）应用层攻击

应用层攻击利用 Web 应用中的漏洞，通过向服务器发送恶意数据或请求，达到窃取数据、破坏服务或绕过安全机制的目的。

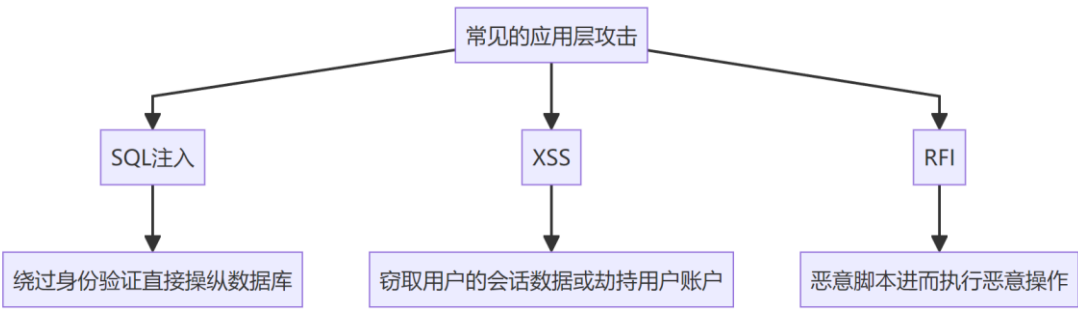


图 3 常见应用层攻击类型

漏洞分析

1. 数据隐私保护：

2025 年 1 月的数据泄露事件中，超过 100 万条用户聊天记录与 API 密钥因未加密的 ClickHouse 数据库暴露而泄露^[4]。

2. 基础设施与网络架构的脆弱性

2025 年 1 月，DeepSeek 遭遇峰值 3.2Tbps 的 DDoS 攻击，导致官网瘫痪 48 小时，初期防御体系未能有效过滤异常流量。这种大规模攻击暴露了其带宽管理与应急响应机制的不足。同时，反射放大攻击暴露了其带宽管理缺陷，无法应对大规模的网络流量，不仅可能导致网络拥塞和服务质量下降，还会使得产品在 DDoS 攻击中脆弱不堪。

3. 供应链与第三方风险：

部分攻击这利用 PyPI 平台伪装成 DeepSeek API 客户端的恶意软件包，窃取了环境变量与用户数据。

4. 越狱攻击与对抗性漏洞

Qualys 测试显示，DeepSeek 在不同的越狱技术下的失败率超过 58%^[4]。这种高失败率表明其安全防护机制几乎无效，极易被绕过。

5. 算法设计缺陷

DeepSeek 使用的强化学习策略虽然能够提升推理效率，但是也牺牲了安全对齐机制，导致模型极易被自动化工具绕过安全限制。

防护方案设计与分析

根据分析所得的主要攻击手段与漏洞，结合网络分层 TCP/IP 模型，提出如下的防护方案。

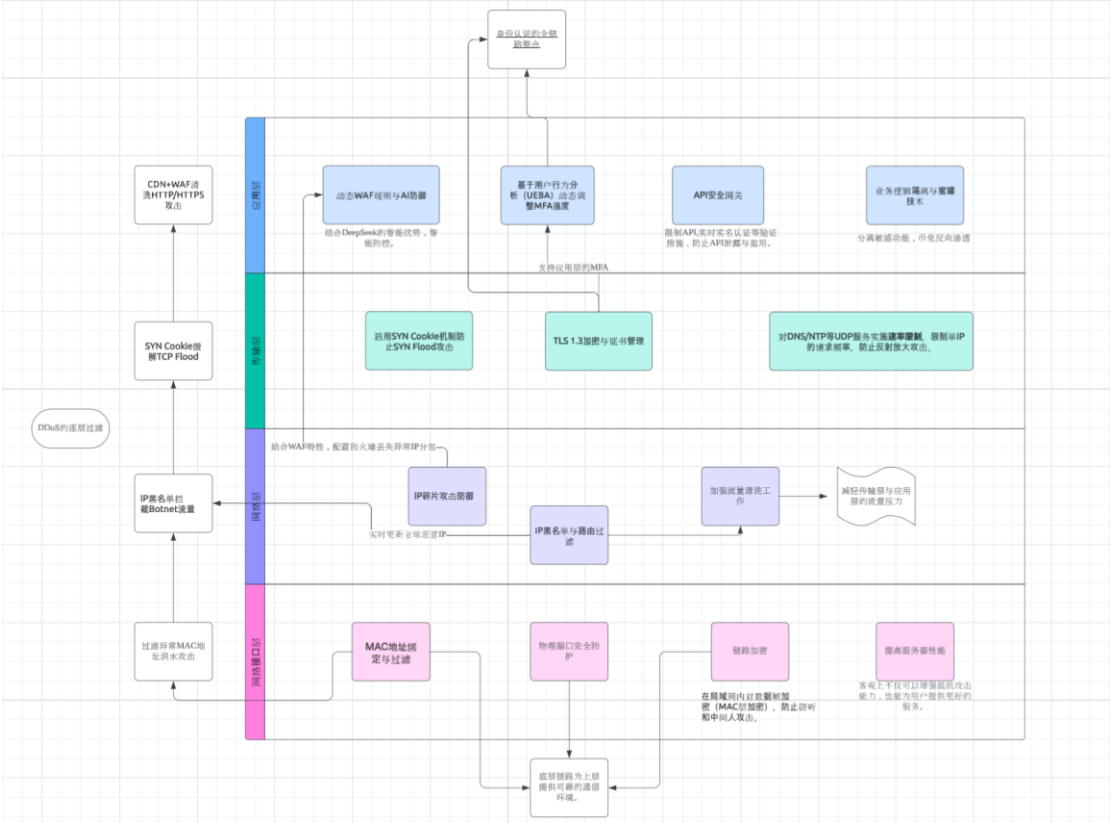


图 4 分层防护方案 （注：底色块分别对应各层次措施，白色块对应实现功能的意义）

首先，在网络接口层，主要通过 MAC 地址绑定与过滤、物理端口安全的保证以及链路加密，对物理设备与链路通信进行防护，同时也应加强服务器性能，由此为上层提供更可靠的通信环境。接着，在网络层主要保护 IP 地址与路由安全，过滤已知的攻击源头，直接减轻传输层和应用层的流量压力。随后在传输层中，确保端到端的链接安全为后续应用层数据提供保密性。最后在应用层中，利用动态 WAF 规则，依靠 DeepSeek 本身高能的智能特性，结合 AI 检测攻击，为用户提供更好的应用体验。

此外，通过传输层 TLS 加密与应用层的 AES 存储加密，可以有效的解决过去用户数据隐私性不足的痛点。同时利用 MFA、证书双向认证、IP 信誉库，可有效阻断自动化 HTTP 攻击与恶意脚本攻击，实现身份验证的全链路整合。利用大数据分析技术，进行全流量分析与威胁狩猎，增强防御的纵深度。

本方案通过“分层加固+跨层联动”，理论上可以构建多层冗余的防御体系，通过跨层协同，实现攻击的早期拦截（例：IP 层阻断 Botnet）、复杂攻击在应用层精准识别（例：WAF 拦截 SQL 注入）最终形成“漏斗”式的防御模型，攻击压力自上而下递减，保障核心服务的稳定运行。

结语

DeepSeek 遭遇的网络攻击事件凸显了人工智能公司在网络安全方面的紧迫性。通过加大技术防护的投入、优化系统架构、提高安全意识，DeepSeek 可以显著提高其抵御网络攻击的能力，保护用户数据安全，并恢复公众对 AI 工具的信任。

此外，据研究发现，DeepSeek 的安全防护措施存在缺陷，未能有效阻止恶意提示 (prompt)，可能导致模型生成有害内容^[7]。DeepSeek 自身还应加强模型的优化与增强，防止 AI 工具成为威胁网络安全与现实安全的“帮凶”。

参考文献与新闻报道

- [1] [deepseek-ai/DeepSeek-R1](#)
- [2] [DeepSeek 遭受大量海外攻击，奇安信：面临前所未有安全考验，攻击将持续 10%公司 澎湃新闻-The Paper](#)
- [3] [从 DeepSeek 安全问题看 HTTP 代理攻击 | CN-SEC 中文网](#)
- [4] [Exposed DeepSeek Database Revealed Chat Prompts and Internal Data | WIRED](#)
- [5] [DeepSeek-R1 LLM Fails Over Half of Jailbreak Attacks in Security Analysis](#)
- [6] [关于防范针对 DeepSeek 本地化部署实施网络攻击的风险提示 澎湃号·政务 澎湃新闻-The Paper](#)
- [7] [DeepSeek' s Safety Guardrails Failed Every Test Researchers Threw at Its AI Chatbot | WIRED](#)